

Table of Contents

Cisco Secure Workload — SWIFT Customer Security Controls Framework (CSCF)

Reference Design | Financial Messaging & SWIFT Secure Zone Accounts

Version: 1.0

Use Case: Fresh Install, Hybrid Environment (On-Prem + Cloud)

Framework Reference: SWIFT Customer Security Controls Framework (CSCF) v2024

Reader's Guide

Who this is for. Institutions that participate in the SWIFT network, their messaging interface operators, security teams preparing for the SWIFT Customer Security Programme (CSP) attestation or independent assessment, and infrastructure teams responsible for the **SWIFT secure zone** architecture.

Questions this reference design helps you answer:

- *Can I prove the SWIFT secure zone is logically isolated from general corporate IT and that policy enforcement matches the documented connection matrix? (CSCF 1.1, 2.1)*
- *Can I demonstrate that workloads in the secure zone cannot initiate direct paths to the public Internet at the workload enforcement layer? (CSCF 1.4)*
- *When an operator uses a privileged path, can I show which processes and flows were involved—not only that an account logged in? (CSCF 1.2, 5.1)*
- *Can I detect and block or alert on cleartext operator protocols inside the zone if they appear? (CSCF 2.6)*
- *For CSP evidence windows, what continuous artifacts complement my AV, SIEM, and IR playbooks at the workload tier? (CSCF 6.1, 6.4, 7.1)*

What you'll need. Your current SWIFT architecture classification (connectivity and component model per SWIFT guidance), the official CSCF v2024 control matrix for your **architecture type** (mandatory vs advisory applicability), network diagrams, a list of SWIFT-related components (SMC, connectors, gateways, HSM adjacency, jump hosts), and either CSW already deployed or scope decisions for deployment.

Where to start. Sections 1–2 for executive alignment; 3–6 to deploy and baseline; 7 for control mapping and evidence; 8–9 for boundaries and audit preparation; Appendix A to reconcile **Mandatory (M)** vs **Advisory (A)** labels with your SWIFT architecture row.

CSW primer — if you are new to Cisco Secure Workload

Cisco Secure Workload (CSW) is a **workload protection platform**. A lightweight **agent** on each server/VM/container observes processes and network flows; **cloud connectors** add AWS/Azure/GCP inventory where agents are not deployed.

CSW term	Meaning	Why compliance teams care
Scope	Logical boundary (CDE, PHI zone, CUI enclave)	Defines the systems you must prove are isolated
Label / filter	Tag or query assigning workloads to scopes	Automates scope membership — reduces drift
ADM	Application Dependency Mapping from observed traffic	Live network/data-flow diagram for assessors
Workspace	Policy container for one scope or application	Where allow/deny rules are authored
Monitor → Simulation → Enforce	Safe rollout sequence	Simulation = change-board evidence before blocking traffic
Denied Connections	Log of flows blocked by policy	Primary proof that enforcement operates

Console areas: Investigate (inventory, flows, vulns) · Defend/Segmentation (policy) · Manage (agents) · Platform (connectors) · Administration (audit log)

Read next: [Compliance evidence playbook](#) (full step-by-step) · [About CSW](#) (platform intro)

Universal evidence workflow

Execute these phases for **this framework's** compliance boundary. Map exports to control IDs in the **Reporting & Evidence** section below.

Phase	Goal	Key CSW actions	Typical duration
1 — Coverage	Every in-scope workload in CSW	Install agents/connectors ; apply compliance labels; create scope	Days 1–10
2 — Baseline	Machine-	Run ADM ≥2	Days 11–28

Phase	Goal	Key CSW actions	Typical duration
	generated flow map	weeks; export clusters; app-owner signoff	
3 — Policy	Designed isolation before enforce	Build workspace; Simulation mode; fix false positives	Days 29–45
4 — Operate	Continuous proof between audits	Enforce; quarterly export pack; ADM refresh every 90 days	Ongoing

Phase 1 checklist (coverage)

- ☐ In-scope host list reconciled to CSW Inventory (100% or documented exceptions)
- ☐ Labels applied: `compliance:<framework>`, `data:<classification>`, `env:<tier>`
- ☐ CSW scope created matching compliance boundary
- ☐ **Export:** inventory CSV + agent status screenshot

Phase 2 checklist (baseline)

- ☐ ADM running on compliance scope for full business cycle (≥ 2 weeks)
- ☐ Unexpected flows documented (shadow IT, vendor egress, scope creep)
- ☐ App owners signed cluster-to-application mapping
- ☐ **Export:** ADM diagram + flow samples with process context

Phase 3 checklist (policy)

- ☐ Default-deny posture defined for sensitive scope
- ☐ ADM-imported rules refined; Simulation run ≥ 1 week
- ☐ Change tickets for false-positive fixes; exception register updated
- ☐ **Export:** policy export + simulation report

Phase 4 checklist (operate)

- ☐ Enforcement enabled on pilot scope; negative test recorded in Denied Connections
- ☐ Quarterly pack: inventory, policy, denies, vulns, audit log (see playbook)
- ☐ SIEM integration verified (sample events)
- ☐ **Export:** enforcement screenshot + quarterly binder

What CSW evidence does not replace

Physical access, HR/training records, encryption key management, signed BAAs/vendor contracts, formal pen tests, and assessor attestation still require separate programmes. CSW addresses the **workload-resident** slice: segmentation, flows, process context, vuln reachability, and change drift.

CSW effectiveness for this framework

- SWIFT secure zone isolation with mandatory/advisory mapping
- Internet access restriction evidence from deny logs
- Operator session integrity via identity-aware paths (where integrated)

Compared to manual programmes: static diagrams and annual firewall samples age immediately; CSW ties evidence to **live workload behaviour** and produces queryable exports on demand — supporting "operating effectively" language in PCI v4.0, SOC 2 CC7, and HIPAA risk analysis.

1. Overview

SWIFT CSCF v2024 prescribes security controls for users of the SWIFT network. Technical evidence is only one layer: organizational policies, third-party assurance, and physical/logical SWIFT architecture design remain authoritative. **Cisco Secure Workload (CSW)** strengthens the technical story where **workload visibility, microsegmentation, vulnerability–reachability context, and forensic telemetry** apply—especially for the **SWIFT secure zone** and tightly coupled components.

CSW does **not** replace SWIFT connectors, VPNs, bastion patterns, HSMs, or mandated CSP assessments; it complements them with **continuous workload-level enforcement and evidence**.

1.1 CSCF v2024 Control Groupings vs CSW (Summary)

CSCF Group (Illustrative)	Representative Themes	Relevant CSW Capabilities
1 — Secure Environment	Zone protection, privileged access, internet restriction	Microsegmentation, egress enforcement, privileged-flow visibility
2 — Restrict Internet Access & Zone Defences	Internal flows, session confidentiality	Flow telemetry, cleartext protocol detection/blocking
3 — Reduce Attack Surface & Vulnerability	Hardening, patching cadence (org-led)	CVE exposure + reachability, policy compensating controls
4 — Physical Security	Credentials, passwords (largely org/IdP)	Mostly out of scope for CSW (see Section 8)
5 — Manage Identities & Logical Access	Logical access, separation of duties	Identity-aware policy where integrated; scope/label-based segmentation
6 — Detect & Respond & Recover	Malware, logging, IR	Process anomaly signals, flow/process export, forensics

CSCF Group (Illustrative)	Representative Themes	Relevant CSW Capabilities
7 — Cyber Incident & Business Continuity	IR planning, resilience	Timelines from flow/process history; policy snapshots

Note on Mandatory vs Advisory: SWIFT labels each control **Mandatory (M)**, **Advisory (A)**, or **Not Applicable (N/A)** depending on your institution’s **architecture type** in the official CSCF matrix. Every control row in Section 7 includes a **typical** M/A hint; **always reconcile** against your attestation pack and official v2024 documentation.

2. Pre-Deployment Checklist

Before deploying CSW sensors into the SWIFT environment:

- ☐ **Architecture type** confirmed and documented (per SWIFT CSCF / connectivity model)
- ☐ **SWIFT secure zone** CIDRs, VLANs, cloud subnets, and management enclaves identified
- ☐ **Data-flow baseline** available or planned (known SMC, middleware, HSM clients, monitoring)
- ☐ CSW cluster (SaaS or on-prem) provisioned; **443 outbound** from workloads approved
- ☐ Linux/Windows sensor compatibility verified for all **in-zone** targets
- ☐ Cloud connectors configured if zone spans **AWS / Azure / GCP**
- ☐ Change windows approved; **enforcement** explicitly *not* enabled Day 1
- ☐ Stakeholders engaged: CISO, SWIFT Coordinator, Network Ops, SOC/IR, Internal Audit
- ☐ **Segregation of duties:** CSW admin accounts are not shared with SWIFT operators

3. Phase 1 — Sensor Deployment (Days 1–5)

3.1 Secure Zone Workloads (On-Premises)

Install software sensors on servers and operator jump systems in scope:

```
# Linux (RHEL/CentOS/Ubuntu) – example
sudo rpm -ivh tet-sensor-<version>.rpm      # RHEL/CentOS family
sudo dpkg -i tet-sensor-<version>.deb        # Debian/Ubuntu

# Verify agent health
systemctl status csw-agent || systemctl status tetration-agent
```

Baseline posture:

Setting	Initial Value	Rationale
Enforcement	Monitoring /	Prevent production

Setting	Initial Value	Rationale
	Simulation only	messaging disruption
Flow + process collection	Enabled	CSP evidence and IR timelines
Labels	compliance:swift, zone:swift-secure	Scope accuracy

3.2 Cloud Workloads (if applicable)

Use **sensors on instances** and/or **cloud connectors** for inventory and flow context:

CSW UI → Platform → External Orchestrators

- Add AWS / Azure / GCP connector
- Least-privilege IAM / service principal
- Enable flow log ingestion where used for the secure zone

3.3 Sensor Validation

CSW UI → Manage → Agents

- Filter: label zone=swift-secure (or equivalent)
- Validate "Active" telemetry for every production messaging component
- Confirm agent version currency (document for audit evidence)

4. Phase 2 — Scope Design & Inventory (Days 6–12)

4.1 Recommended CSW Scope Hierarchy (SWIFT Secure Zone)

Root Scope

```

├── SWIFT-Program
│   ├── SWIFT-Secure-Zone (strict enforcement target)
│   │   ├── Messaging-Interfaces (SMC / middleware / connectors per
│   │   │   your architecture)
│   │   ├── Proxy-Gateway-Layer (if present)
│   │   ├── Operator-Jump-Hosts
│   │   └── Local-Logging-Forwarders
│   ├── SWIFT-Adjacent (controlled interfaces only)
│   │   ├── SIEM-Collectors (east-west allowlist only)
│   │   └── Enterprise-AD-LDAP-Replicas (if architecture requires –
│   │       justify narrowly)
│   └── Backup-Control-Plane (if in connector path)
└── Corporate-IT (out of SWIFT zone – default deny from zone)
  
```

4.2 Discovery Filters (Examples)

Create saved inventory queries to catch drift:

Filter: SWIFT-Candidate-Processes

- Process name contains: (align to YOUR stack – e.g. smc, swift, mq,

xml gateway binaries)

- Listening ports: (document your standard listener map – e.g. messaging middleware)

Filter: Privileged-Operations

- User context in [operator groups] AND process in [shells, remote admin tools]

4.3 Labelling Strategy

Label Key	Example Values	Purpose
zone	swift-secure, adjacent, corporate	Boundary for policy
compliance	swift-cscf	Reporting filters
role	smc, gateway, jump, logging	Rule targeting
env	production, dr	Change control

5. Phase 3 — Visibility, Baseline & ADM (Days 10–28)

5.1 Application Dependency Mapping (ADM)

ADM produces the **live internal data-flow graph** required to validate CSCF **internal flow** expectations and to author least-privilege rules.

Csw UI → Investigate → Application Dependency Mapping

- New Workspace
- Name: "SWIFT-CSCF-ADM-2026"
- Scope: SWIFT-Secure-Zone (+ Adjacent if needed for cross-scope flows)
- Time Window: minimum 2–4 weeks (cover end-of-month / batch cycles)
- Enable process context (and user context where available)

5.2 Baseline Review Questions (CSCF-Oriented)

Question	CSCF Tie-In
Which flows exit the secure zone, and to exactly which adjacencies?	1.1, 2.1
Are there any unexpected internet-bound egress attempts from zone members?	1.4
Do operator sessions traverse cleartext protocols internally?	2.6
Which hosts initiate administrative tooling sessions inbound to SMC/gateway tiers?	1.2, 5.1

5.3 Export for Architecture Evidence

Export ADM clusters and edge lists after stabilisation:

CSW UI → Investigate → Application Dependency Mapping
→ Open workspace → Export (per product UI) cluster + edge summaries

Store exports with **version, time window, and scope** metadata for CSP folders.

6. Phase 4 — Policy Design & Enforcement (Days 22–45)

6.1 Policy Workspace

CSW UI → Defend → Segmentation
→ New Workspace: "SWIFT-CSCF-Enforcement"
→ Scope: SWIFT-Secure-Zone
→ Import ADM-suggested policies → refine to match ****documented****
connection matrix
→ Mode: Simulation → Enforcement (staged)

6.2 Illustrative Policy Patterns (YAML-Style Snippets)

Adapt field names to your CSW release; treat these as **logical** patterns.

Default posture — deny SWIFT secure zone to Internet at workload layer:

```
# Logical illustration – SWIFT-Secure-Zone → Internet egress denial
rules:
- name: SWIFT-Zone-Deny-Internet-Egress
  action: DENY
  source:
    scope: SWIFT-Secure-Zone
  destination:
    internet: true
  layer: workload
  rationale: "CSCF 1.4 – restriction of internet access (defence in
depth)"
```

Allow only approved east–west dependencies (replace ports with your architecture):

```
rules:
- name: SWIFT-Allow-Approved-Dependencies
  action: ALLOW
  source:
    scope: SWIFT-Secure-Zone
  destination:
    scope: SWIFT-Adjacent
  services:
  - protocol: TCP
    ports: [443, 8443, <your-messaging-ports>]
```

Privileged operator path — alert-first, then enforce in tranches:

```
rules:
- name: Operator-Jump-To-SMC-Allowlist
  action: ALLOW
  source:
    labels:
      role: jump
  destination:
    labels:
      role: smc
  services:
    - protocol: TCP
      ports: [<admin-ports>]
```

Cleartext detection (Telnet/FTP examples — extend to other plaintext stacks):

```
rules:
- name: Block-Cleartext-Inside-Secure-Zone
  action: DENY # or ALERT-only during early simulation
  source:
    scope: SWIFT-Secure-Zone
  destination:
    scope: SWIFT-Secure-Zone
  application:
    protocol_detect: [telnet, ftp]
```

6.3 Enforcement Progression

Stage	Mode	Duration	Goal
A	Simulation	≥2 weeks	Validate messaging + batch; capture false positives
B	Selective DENY (internet egress)	1–2 weeks	Prove 1.4-style controls without touching core east-west
C	Full allowlist + default deny	Ongoing	Formal least privilege

7. Phase 5 — Control-by-Control Mapping (CSCF v2024)

M/A column: **M** = typically **Mandatory**, **A** = typically **Advisory** for many user architectures in public CSCF summaries. **Confirm against your official v2024 matrix row** (architecture-dependent).

CSCF Ref	Title (Short)	Typical M/A*	CSW Capability	Evidence Produced
1.1	SWIFT environment protection	M	Microsegmentation of secure zone; deny unapproved cross-zone paths; ADM-backed allowlists	Policy workspace export; simulation vs enforcement reports; scope membership exports
1.2	OS privileged account control	M	Process + flow visibility for privileged sessions; anomaly alerts on new admin paths	Flow search with process + user context ; alerts on disallowed admin stacks
1.4	Restriction of internet access	M	Explicit DENY secure-zone → Internet at workload layer; egress attempt visibility	Block counters / violation logs; flow reports showing no successful egress (or documented exceptions)
2.1	Internal data flow security	A/M†	ADM + flow telemetry for intra-zone and zone-to-adjacency conversations	ADM exports; edge list tagged by time window; diff between quarters
2.6	Operator session confidentiality	M	Plaintext protocol detection (e.g., Telnet/FTP) and blocking/alerts; enforce TLS-only paths where	Protocol-based rule hits; remediation tickets; pre/post flow captures

CSCF Ref	Title (Short)	Typical M/A*	CSW Capability	Evidence Produced
			architecturally valid	
4.1	Password policy	M	Out of scope — IdP / directory / OS password controls (see Section 8)	Boundary statement + pointer to directory audit
5.1	Logical access control	M	Identity-aware policy (where integrated) + strict role/label-scoped rules for operator entry points	Rule sets tied to jump/SMC roles; access-path flow history
6.1	Malware protection	M	Process anomaly detection; execution lineage; complementary to AV/EDR	Anomaly timelines; correlations with AV alerts (operational narrative)
6.4	Logging & monitoring	M	Continuous flow + process telemetry; export to SIEM via product integrations or scheduled exports	Sensor uptime reports; export samples; SOC reference design references
7.1	Cyber incident response planning	M	Forensic reconstruction using historical flows/processes; policy snapshot/versioning for	Incident-window exports; before/after policy diffs; analyst query audit trail

CSCF Ref	Title (Short)	Typical M/A*	CSW Capability	Evidence Produced
			change control	

† **2.1** applicability (M vs A) is architecture-dependent in CSCF—verify your matrix.

* **Mandatory/Advisory** classifications **must** be taken from the official SWIFT CSCF v2024 documentation for your institution’s architecture; the M/A hints here support reference design navigation only.

7.1 Additional CSCF Controls (Illustrative Technical Touchpoints)

CSCF Area	Typical M/A	CSW-Relevant Angle	Evidence Hook
2.x / 3.x System hardening & vulnerability	Mixed	CVE + reachability prioritisation; narrow allow rules as compensating controls while patching	Vulnerability scoped reports; policy exception records
6.x Detection sub-controls	Mixed	Workload segmentation blocks; east-west alerts	Alert exports; MTTD/MTTR narrative support

8. Boundaries — What CSW Does **Not** Cover

Be explicit with assessors to avoid **over-claiming**:

Topic	Boundary
SWIFT contractual & organizational CSP	CSW does not complete the annual attestation or independent assessment for you.
Architecture design approvals	Physical/logical SWIFT architecture choices, VPNs, HW security modules, and connector placement remain outside CSW.
Password / MFA / account lifecycle	Directory controls, MFA enforcement, password length/history (e.g., CSCF 4.1) are IdP/OS responsibilities.
Log tamper protection & retention law	CSW generates telemetry; log integrity, WORM storage, legal

Topic	Boundary
	hold , and contractual retention are SIEM/ops/legal domains.
Malware efficacy	CSW complements AV/EDR but does not replace signature/engine coverage or host isolation products.
Patch installation	CSW informs risk; change execution is IT operations.
People & process controls	Training, background checks, vendor SLAs, and IR tabletop governance remain organizational.

9. Audit Preparation & Evidence Export

9.1 Recommended Quarterly Evidence Pack (CSW Portions)

Evidence Item	CSW Source	Maps To (Examples)
Secure-zone inventory snapshot	Manage → Inventory / Agents	1.1, 5.1
Policy workspace export + version	Defend → Segmentation	1.1, 1.4, 2.1, 5.1
Simulation vs enforcement history	Policy analysis / audit	1.4, 2.1
ADM graph export (time-bounded)	Investigate → ADM	2.1
Flow search export (representative samples)	Investigate → Flow Search	2.1, 6.4, 7.1
Violation / block statistics	Alerts / policy hits	1.4, 6.4
Vulnerability exposure report (zone scoped)	Investigate → Vulnerability	3.x hardening narrative
Agent coverage & health dashboard	Operations views	6.4

9.2 Bash-Oriented Export Patterns (Examples)

When APIs/CLI are available in your deployment, wrap repeatable exports:

```
#!/usr/bin/env bash
# Illustrative – replace with your CSW API/CLI equivalents
set -euo pipefail
QUARTER="2026Q2"
SCOPE="SWIFT-Secure-Zone"
OUTDIR="./swift_csp_evidence_${QUARTER}"
```

```

mkdir -p "${OUTDIR}"
# pseudo-calls – implement using your supported automation
# csw inventory export --scope "${SCOPE}" > "${OUTDIR}/inventory.json"
# csw policy export --workspace SWIFT-CSCF-Enforcement >
"${OUTDIR}/policies.json"
# csw adm export --workspace SWIFT-CSCF-ADM-2026 > "${OUTDIR}/adm-
edges.csv"

echo "Package ${OUTDIR} with cryptographic hash manifest for audit
chain of custody."
sha256sum "${OUTDIR}"/.* > "${OUTDIR}/SHA256SUMS.txt"

```

9.3 Incident Response Evidence Collection

CSW UI → Investigate → Flow Search

- Time range: IR window (UTC-documented)
- Source/Destination: affected workload identities
- Export: CSV/JSON + process metadata

CSW UI → Investigate → Process Search

- Scope: SWIFT-Secure-Zone
- Parent/child lineage for suspicious execution

Retain exports under your **records management** policy; correlate with tickets, timelines, and third-party forensics.

10. Monitoring & Alerting (Operationalisation)

Alert	Trigger	CSCF Touchpoint
Secure-zone internet egress attempt	Deny or detect on Internet destinations	1.4
New unexpected east-west dependency	Baseline deviation vs ADM	2.1
Cleartext protocol inside zone	telnet/ftp/other plaintext signatures	2.6
New privileged path to SMC tier	First-seen admin flow	1.2, 5.1
Sensor gap	Agent inactive	6.4
Critical CVE on in-zone production	Vulnerability rule	3.x

11. Common Pitfalls

Pitfall	Mitigation
Mapping organizational Mandatory controls without architecture row	Import official v2024 matrix into Appendix A; color-code rows
Enforcing too aggressively during migration	Long simulation; staged tranches; maintenance windows
Mistaking VPN Internet breakout for "no internet"	Trace actual default routes and egress from each subnet
Operator shared jump boxes blur accountability	Pair CSW user context with named accounts at the bastion
HSM traffic mis-modelled	Document crypto client flows; avoid over-broad blocks

Appendix A — Mandatory vs Advisory (Official Source of Truth)

1. Obtain **CSCF v2024** from SWIFT's authorised customer portal / your compliance lead.
2. Locate the **control applicability table** for your **architecture type**.
3. For each control in Section 7, replace the **Typical M/A** hint with your **official M/A/N/A** flag.
4. Store the signed applicability worksheet next to CSW exports in the evidence folder.

Appendix B — Sample Evidence Retention Notes

- Align CSW export retention with **SOC / IR** and **records management** policy.
- Where cryptographic **integrity** of exports is required, package `SHA256SUMS.txt` and transfer via approved secure exchange.

Related Frameworks

- [PCI DSS v4.0](#) — technical overlap in segmentation and logging narratives for hybrid banking stacks.
- [ISO/IEC 27001:2022](#) — ISMS-aligned evidence packaging.
- [NIST SP 800-53 Rev 5](#) — control families helpful for mapping CSP evidence into federal-style audits.

Document prepared for Cisco financial services engagements. Replace [Customer Name] and bracketed placeholders before customer delivery.